

Unidad 1: Seguridad en los Sistemas de Información- Introducción

Contenido

Seguridad de la Información	2
Seguridad Informática.....	3
Concepto de Seguridad Informática vs Seguridad de la Información.....	4
Causas de la Inseguridad	5
Deficiencias tecnológicas.....	5
Deficiencias de la política de seguridad	6
Deficiencias de configuración	6
Virus Informáticos.....	7
Concepto de Autenticación	8
Mecanismos preventivos en seguridad informática.....	9
Mecanismos detectivos en seguridad informática	10
Concepto de encriptación en seguridad informática.....	11
Métodos de encriptación	12
Encriptación simétrica.....	12
Encriptación asimétrica	13
Firma digital.....	13
Encriptación WEP y WPA.....	13
Ataques. Clasificación de Ataques:	14
Ataques pasivos	14
Ataques activos.....	15
Ataques: Objetivos y Comportamientos	16
¿Cómo podemos protegernos?	17
Usar siempre protección antivirus.....	18
Cambiar las configuraciones predeterminadas	18
Usar un cortafuego (firewall).....	19
No abrir ficheros adjuntos desconocidos en correos electrónicos.....	19
No ejecutar programas de origen desconocido.....	19
Mantener actualizadas todas las aplicaciones, incluyendo el sistema operativo	19
Apagar el ordenador o desconectarlo de la red cuando no lo use	19
Hacer copias de seguridad de los datos críticos y crear un disco de arranque	19

Seguridad de la Información

La **seguridad informática y la seguridad de la información** pueden parecer lo mismo. Sobre todo, si se tiene en cuenta que el desarrollo y la evolución de la tecnología tiende hacia el modelo de digitalizar y manejar **cualquier tipo de información** mediante un sistema informático. No obstante, aunque se encuentran destinados a vivir en armonía y trabajar de forma conjunta, cada una de las áreas de seguridad tiene objetivos y actividades diferentes.

La seguridad informática se describe como la **distinción táctica y operacional de la seguridad**, mientras que la seguridad de la información es la línea estratégica de la seguridad.

Se debe tener en cuenta la definición de la seguridad de la información como la disciplina que se encarga de la implementación técnica de la **protección de la información**, el despliegue de las tecnologías que establecen de forma que se aseguran las situaciones de fallas parciales o totales, cuando la información es el activo que se encuentra en riesgo.

Seguridad Informática (IT security) es la disciplina que se encarga de llevar a cabo las **soluciones técnicas** de protección de la información.

Por otro lado, la seguridad de la información es la disciplina que nos habla de los riesgos, de las amenazas, de los análisis de escenarios, de las **buenas prácticas y los esquemas normativos**, que nos exigen niveles de aseguramiento de procesos y de tecnología para elevar el nivel de confianza en la creación, utilización, almacenaje, transmisión, recuperación y disposición final de la información.

Seguridad de la Información (Information Security) es la disciplina que se encarga de proporcionar la **evaluación de riesgos y amenazas**, trazar el plan de acción y adecuación para minimizar los riesgos, bajo la normativa o las buenas prácticas con el objetivo de asegurar la confidencialidad, integridad y disponibilidad del manejo de la **información de activos**.



La seguridad de la información es la disciplina que se encarga de garantizar la confidencialidad, **integridad y disponibilidad de la información**. Para conseguir el objetivo se apoya a la seguridad informática, es decir, a pesar de ser disciplinas diferentes, la una no puede

ir sin la otra. De forma que la seguridad de la información será la encargada de regular y **establecer las pautas a seguir** para la protección de la información.

Es habitual que la seguridad de la información se apoye en la política de seguridad que se desarrolla mediante la **elaboración de un plan director de seguridad**. La dirección será la encargada de marcar todas las líneas de actuación en materia de seguridad y mediante el plan director para determinar las medidas tanto técnicas como procedimentales que garantice los **objetivos marcados por la política de seguridad**.

Las medidas técnicas serán llevadas a cabo por el equipo de seguridad informática, **administradores de sistemas y seguridad**, los roles de seguridad, que hablaremos en otra ocasión que implantan las medidas necesarias para el **cumplimiento de la política de seguridad y el análisis de riesgos** en el que se debería basar la política.

Muchas veces escuchamos hablar de seguridad de la información y seguridad informática indistintamente. Por una parte, la **seguridad informática protege el sistema informático**, tratando de asegurar la integridad y la privacidad de la información que contiene. Por lo tanto, podríamos decir, que se trata de implementar medidas técnicas que **preservaran las infraestructuras** y de comunicación que soportan la operación de una empresa, es decir, el hardware y el software empleados por la empresa.

La seguridad de la información va mucho más allá, puesto que intenta proveer de **medidas de seguridad** a otros medios donde se localiza la información como:

- Impresos en papel
- Discos duros
- Medidas de seguridad respecto de las personas que la conocen

Se encuentra orientado no solo a **preservar la información**, sino además a mejorar los procesos de negocio. Se deben añadir a las medidas técnicas, otras organizativas o legales que permitan a la organización asegurarse una mayor solidez de la **confidencialidad, integridad y disponibilidad** de los sistemas de información.

La **seguridad de la información** integra toda la información independientemente del medio en el que esté. La seguridad informática atiende sólo a la protección de las instalaciones informáticas y de la información en medios digitales.

La implementación de la norma ISO 27001 de seguridad de la información, además de reducir el **impacto de los riesgos y amenazas**, entre otros beneficios, mejora la planificación y la gestión de la seguridad de la empresa. Establece garantías de continuidad del negocio en caso de contingencia, proporciona una imagen de prestigio frente a terceros y da cumplimiento de normativas nacionales.

Seguridad Informática

Al oír hablar sobre “Seguridad Informática” es común asociar el concepto con “usuarios – intrusos” que acceden a un equipo informático desde un lugar remoto con la intención de desequilibrar el “normal funcionamiento” de un sistema, desequilibrando la economía de un país, realizando un sabotaje, robando datos cruciales, o alterando información vital para la administración o utilización de dicho sistema.

La definición técnica de la Seguridad Informática es la seguridad que engloba la protección del factor computacional en los dispositivos electrónicos, refiriéndonos a aquellas combinaciones entre hardware y software capaz de manipular información a través de su funcionamiento.

No debemos pensar que los usuarios e intrusos constituyen el único peligro al que nos vemos expuestos. Un virus que ingresa a través de un programa o documento de procedencia dudosa, una incorrecta instalación eléctrica o un uso desacertado de los recursos disponibles en el momento de mantener la integridad de la información en un sistema perfectamente aislado puede ser una razón para estar en peligro.

Es importante no temer a lo que pueda suceder, sino ser conscientes de los problemas que pueden presentarse en un ámbito informático, teniendo en cuenta QUE nos puede suceder, COMO y CUANDO.

La seguridad siempre busca la gestión de riesgos, esto quiere decir que se tenga siempre una forma de evitarlo o prevenirlo y que se pueda realizar ciertas acciones para evitar esas situaciones de la mejor forma. Se definió que la seguridad podría ser catalogada como la ausencia de riesgo, la definición de este término involucra cuatro acciones que siempre están inmersas en cualquier asunto de seguridad como son:

- Prevención del riesgo
- Transferir el riesgo
- Mitigar el riesgo
- Aceptar el riesgo

Así que, cuando se está buscando hacer algo más seguro, estas acciones son algo que se debe de considerar sin importar el área, se aplica a cualquier intento de tener mejor o mayor seguridad en cualquier tema que se requiera.

Concepto de Seguridad Informática vs Seguridad de la Información

Lo primero que se debe mencionar es que en muchos casos se suelen confundir dos conceptos la seguridad informática y la seguridad de la información, aunque suenen muy parecidos tienen puntos clave que hacen una diferencia. La seguridad informática se encarga de la seguridad del medio informático, según varios autores la informática es la ciencia encargada de los procesos, técnicas y métodos que buscan procesar almacenar y transmitir la información, mientras tanto la seguridad de la información no se preocupa sólo por el medio informático, se preocupa por todo aquello que pueda contener información, en resumen, esto quiere decir que se preocupa por casi todo, lo que conlleva a afirmar que existen varias diferencias, pero lo más relevante es el universo que manejan cada uno de los conceptos en el medio informático. Se puede definir a la seguridad informática como la disciplina encargada de plantear y diseñar las normas, procedimientos, métodos y técnicas con el fin de obtener que un sistema de información sea seguro, confiable y sobre todo que tenga disponibilidad. Actualmente la informática está siendo inundada por toda la información posible, pero la información por sí sola sigue siendo un universo más grande y en muchos casos más compleja de manejar, ya que los procesos en muchos casos no son tan visibles para los involucrados. La principal tarea de la seguridad informática es la de minimizar los riesgos, en este caso provienen de muchas partes, puede ser de la entrada de datos, del medio que transporta la información, del hardware que es usado para transmitir y recibir, los mismos usuarios y hasta por los mismos protocolos que se están implementando, pero siempre la tarea principal es minimizar los riesgos para obtener mejor y

mayor seguridad. Lo que debe contemplar la seguridad se puede clasificar en tres partes como son los siguientes:

- Los usuarios
- La información, y
- La infraestructura

Los **usuarios** son considerados como el eslabón más débil de la cadena, ya que a las personas es imposible de controlar, un usuario puede un día cometer un error y olvidar algo o tener un accidente y este suceso puede echar a perder el trabajo de mucho tiempo, en muchos casos el sistema y la información deben de protegerse del mismo usuario.

La **información** se considera como el oro de la seguridad informática ya que es lo que se desea proteger y lo que tiene que estar a salvo, en otras palabras, se le dice que es el principal activo.

Por último, está la **infraestructura**; esté puede ser uno de los medios más controlados, pero eso no implica que sea el que corre menos riesgos, siempre dependerá de los procesos que se manejan. Se deben de considerar problemas complejos, como los de un acceso no permitido, robo de identidad, hasta los daños más comunes, por ejemplo, robo del equipo, inundaciones, incendios o cualquier otro desastre natural que puede tener el material físico del sistema de la organización.⁵ Se puede afirmar que la seguridad informática puede definirse como el conjunto de métodos y de varias herramientas para proteger el principal activo de una organización como lo es la información o los sistemas ante una eventual amenaza que se pueda suscitar.

Causas de la Inseguridad

La inseguridad de los sistemas informáticos y de las redes va más allá de los virus informáticos conocidos. La introducción de mecanismos de protección es una prioridad para cualquier empresa. Los atacantes a una red de telecomunicación no necesitan estar en contacto físico con la víctima; los datos pueden ser fácilmente copiados, transmitidos, modificados o destruidos cuando son transmitidos por la red. Como resultado, si no se dispone de los mecanismos de protección adecuados resulta difícil identificar al atacante: no hay huellas y el marco legal no está suficientemente actualizado para tratar este tipo de delitos.

La naturaleza en tiempo real de Internet añade una nueva dimensión a la delincuencia: es instantáneo.

Aunque existen muchas causas para los problemas de seguridad, por lo menos podemos mencionar tres tipos de deficiencias fundamentales que dan lugar a dichos problemas:

- Deficiencias tecnológicas
- Deficiencias de la política de seguridad
- Deficiencias de configuración

Deficiencias tecnológicas

Cada tecnología tiene algunas deficiencias inherentes conocidas o desconocidas, o vulnerabilidades que pueden ser explotadas por un atacante suficientemente motivado. Algunas deficiencias son ampliamente publicitadas en los medios de comunicación porque están asociadas con un producto bien conocido. Esto no significa que otros desarrollos o sistemas sean seguros. El hecho de que a nadie le importe lo suficiente un sistema como para hackearlo no significa necesariamente que sea seguro. Entre otras, podemos mencionar las siguientes deficiencias:

- Los protocolos de Internet no fueron diseñados pensando en la seguridad de las comunicaciones. Actualmente se emplean servicios de seguridad y las mejores prácticas posibles para reducir los riesgos.
- Sistemas Operativos. Independientemente del fabricante o si se trata de un producto propietario o un desarrollo abierto, todos los sistemas operativos (SO) tienen vulnerabilidades que deben ser abordadas mediante parches, actualizaciones ...
- Debilidades de los accesorios y equipos de comunicación con la red. Tanto los accesorios que permiten la comunicación de un dispositivo con la red, como los equipos de red propiamente dichos (routers, ...) pueden tener vulnerabilidades, a menudo llamadas "agujeros" que pueden ser aprovechadas por atacantes maliciosos. Siempre que sea posible se deben aplicar parches y actualizaciones para eliminar o mitigar los problemas conocidos.

Deficiencias de la política de seguridad

Una deficiencia de la política de seguridad es una frase comodín para indicar que una política de seguridad de la empresa, (o tal vez, la falta de política), genera amenazas de seguridad en la red de forma inconsciente. Los siguientes ejemplos son algunas situaciones que pueden afectar negativamente al sistema informático de un negocio o empresa:

- Inexistencia de un documento escrito donde conste la política de seguridad. Es necesario disponer de un plan documentado y adoptado en el que consten las normativas que se deben cumplir.
- Ausencia de un plan de contingencia para recuperación en caso de desastres. Si no se dispone de dicho plan, en caso que haya un ataque a la red o una catástrofe -un incendio, una inundación o terremoto – el personal disponible improvisará las decisiones a tomar para minimizar las consecuencias. Incluso el personal mejor capacitado y con más experiencia puede tomar decisiones insensatas cuando se enfrentan a un evento catastrófico inesperado.
- Inexistencia de criterios para la modificación o incorporación de hardware o software. Ya sea motivado por el aumento de la productividad o por placer, cualquier incorporación o actualización de software o hardware puede dar lugar a nuevas vulnerabilidades de seguridad. Por ejemplo, añadir un punto de acceso inalámbrico no autorizado a una red puede suponer añadir una puerta trasera virtual a la red y a los recursos de la empresa. Del mismo modo, un protector de pantalla no autorizado puede recopilar el nombre de usuario, contraseñas, y otra información de interés para un atacante.
- Ausencia de supervisión de seguridad. Incluso cuando se despliega una red segura, una falta de supervisión de registros facilitan la proliferación de nuevas vulnerabilidades o un uso no autorizado. El peor caso sería no ser consciente que ha habido un ataque con importantes consecuencias.
- Políticas de empleo. Una rotación de personal con alta frecuencia, falta de oportunidades de los trabajadores o emplear a personas con falta de formación en cargos de responsabilidad pueden impactar de forma negativa en la seguridad de la red.
- Políticas internas. Una política de seguridad laxa puede dar lugar a un ambiente relativamente cómodo para un atacante. Es el síndrome de “aquí todos somos como una familia”. Desafortunadamente, incluso en algunas de las mejores familias hay personas fraudulentas.

Deficiencias de configuración

Muchos dispositivos de red tienen una configuración por defecto que facilita la instalación o intenta conseguir las máximas prestaciones en detrimento de aspectos de seguridad. Una instalación sin la debida atención a la corrección de estas opciones puede acarrear serios problemas potenciales. Algunos problemas comunes de configuración son los siguientes:

- Ineficacia de las listas de control de acceso al no bloquear solicitudes no autorizadas.
- Contraseñas o passwords por defecto, no renovadas en mucho tiempo, o incluso, ausencia de dichas contraseñas.
- Puertos o servicios innecesarios activos.
- Intercambio de Identificadores de usuario (User IDs) y contraseñas sin cifrar.
- Acceso remoto a través de Internet no debidamente protegido

Actualmente resulta fácil identificar las vulnerabilidades más comunes y conseguir la solución adecuada para mitigar el problema.

Virus Informáticos

Unos de los primeros conceptos cuando se habla de seguridad informática, es el de virus informático. Las computadoras solo entienden código binario como ceros y unos, en el mundo de las computadoras y de la informática existen muchos conceptos como el de programas, videojuegos, sistemas operativos y cualquier clase de software.

El software es uno de los conceptos más abstractos, se lo define como todo lo intangible de la computadora, son instrucciones que el ordenador espera que se realicen, las cuales pueden ser instrucciones complejas o instrucciones sencillas.

El término software o programa es utilizado para describir una secuencia de varias instrucciones que es leído por un computador, los cuales son escritos en un determinado lenguaje de programación que pueden ser clasificados de la siguiente manera:

- Lenguaje de máquina
- Lenguaje ensamblador
- Lenguajes de alto nivel

Analizado el tema clave sobre el software, un virus informático es un programa que tiene como objetivo dañar o cambiar el funcionamiento de la computadora. Esta es una definición bastante clara, pero el virus informático no siempre tiene que ser un programa completo, puede ser hasta cierto punto fragmentos de un programa.

Se define al virus informático, como un programa desarrollado en un determinado lenguaje de programación (C++, C, ensamblador, etc.) con el objetivo de infectar uno o varios sistemas informáticos, utilizando varios mecanismos de propagación o auto replicación, el cual trata de reproducirse de forma acelerada para extender su alcance.

Un virus informático puede hacer muchas cosas, por ejemplo, eliminar archivos, evitar accesos a las computadoras, robo de información, bloqueo de funciones de un sistema operativo o de programas dentro de una computadora. También indica que existen varios tipos de virus que se los puede definir de la siguiente manera:

- Virus de sector de arranque (BOOT)
- Virus de archivos ejecutables
- Virus de macros
- Virus de lenguajes de Script
- Malware
- Gusanos
- Troyanos
- Spyware
- Keyloggers

- Adwares
- Dialers
- Backdoors
- Otros
- Rootkits
- Bacterias
- Bombas de tiempo

Se mencionó algunos, ya que la lista es bastante grande pero la mayoría son programados para causar daños relacionados con la red y tener la capacidad de auto propagación, esto quiere decir que se multiplica el mismo muchas veces y se posiciona en partes automatizadas del sistema operativo infectado.

Las bombas de tiempo son virus que se activan al pasar un determinado tiempo o al producir un evento, el que puede ser, por ejemplo, abrir el navegador, pero los eventos suelen ir relacionados con ciertos cálculos matemáticos y registros de memoria, aunque también existen los que se activan con tareas sencillas, estos son solamente algunos de los tipos que se podrían mencionar.

También existe el denominado software malicioso que no es considerado como virus como tal, pero que también genera daños a la computadora, algo muy importante que se debe tener claro es que, el software malicioso debe de tener ciertas características para ser considerados como virus informático, una de las características elementales es que debe de poder reproducirse y generar copias, ya que es la forma en la que se propagan teniendo un comportamiento biológico similar al de los virus que se pueden encontrar en la naturaleza y atacan a los animales y personas.

Concepto de Autenticación

La autenticación se puede definir como un proceso en el que se busca confirmar algo como verdadero, no se busca verificar un usuario, ya que la autenticación no siempre está relacionada con estos, en muchos casos se quiere saber si un cambio o un dato es correcto, no se debe cometer el error en pensar que solamente las personas necesitan este proceso, este puede ser para cualquiera, un sistema, un dispositivo o una persona.

La autenticación es bastante usada en el mundo de la computación, sólo que actualmente la contraseña del correo o de una red social ha hecho olvidar que este método de validación era ya muy común, por ejemplo, todas las credenciales que expiden para realizar una votación en determinado país es un método de autenticación, otro ejemplo es cuando se ingresa a un país y solicitan un documento como la visa o pasaporte, también es un método de autenticación, otro caso es cuando se asigna un número de cuenta o ID de identificación en el trabajo para acceder a ciertas áreas o también para llevar un registro de los movimientos y en caso de ser necesario poder validar esos movimientos. La Figura 1 muestra un ejemplo de autenticación de usuarios.



Existen diversos tipos de autenticación, se va a conocer algunos de ellos los más implementados ya que todos los días se trabaja en encontrar más y mejores métodos.

Se tiene los tipos de autenticación en los que se tiene algo conocido, en teoría únicamente por el usuario, por ejemplo, una contraseña, eso es lo más común, pero en teoría, ya que, si se proporciona el usuario y la contraseña del correo electrónico, también puede entrar otro usuario y no significa que sea la persona dueña de la cuenta.

Otro tipo de autenticación es la que se basa en algo de propiedad del usuario, por ejemplo, la tarjeta de crédito, pasaportes o también son los Tokens que generan números aleatorios o palabras claves. También existen las tarjetas conocidas como inteligentes o que contienen cierta información, se pueden parecer a una tarjeta de crédito, pero el comportamiento o información puede variar.

Se tiene también los tipos de autenticación basados en una característica física, este tipo en comparación con lo que ya se mencionó se puede decir que son los más nuevos. Cuando se habla de características físicas se puede mencionar a:

- La voz
- Las huellas dactilares
- El ojo
- La escritura

La autenticación se puede considerar como parte de un método de control de acceso, la mayoría de las ocasiones esto se complementa con otras partes de un sistema, ya que hoy en día debido al manejo de la información y la personalización de los gadgets que se tiene disponibles, se vuelve una labor compleja la de tener control y manejo dentro del sistema.

Los tipos de autenticación no son excluyentes, así que, si se usa un método, no es una barrera para usar otro, de hecho, en sistemas complejos el usuario se puede encontrar con sistemas que utilizan tres tipos de autenticación, obviamente se tiene que pensar en el usuario, a veces es muy molesto siempre y cuando analizando el costo vs el beneficio.

Mecanismos preventivos en seguridad informática

Los mecanismos correctivos tienen una gran diferencia en tiempo con los mecanismos preventivos, estos se aplican cuando, después de que algo sucedió y la función principal es corregir las consecuencias. Entre las características que tienen los mecanismos correctivos

normalmente son muy caros, esto se debe a que el problema ya se lo tiene encima y no se puede tenerlo durante mucho tiempo, así que, contratar expertos para resolver el problema o el tiempo que le dedicara a el equipo de trabajo siempre va a costar mucho, en un porcentaje muy alto se acaban pagando servicios de solución a otras empresas, adquiriendo soluciones o comprando software y parches de actualización que logran resolver el problema.

Otra característica de los mecanismos correctivos es que el tiempo es limitado, así que el tiempo se vuelve algo muy apreciado en estos casos, pero también es muy escaso. Probablemente la empresa o la persona puede poder obtener dinero, pero tiempo es casi imposible.

Dentro de los mecanismos de corrección se tienen diferentes pasos de ejecución para enfrentar este problema serio en los que se puede mencionar:

Catalogación y asignación de problemas: En este paso se hace un catálogo de los problemas a los que se pueden enfrentar, detectar y clasificar es algo muy recurrente en todo lo relacionado con la seguridad informática, ya que es una forma para poder saber cómo abordar las situaciones y buscar alguna respuesta o solución a lo que se presenta.

Análisis del problema: En este paso es muy evidente que la actividad que se hace es analizar el problema que se ha presentado, en muchos casos esta parte se realiza por los expertos, ya no, por las personas involucradas en el problema.

Análisis de la solución: Antes de intentar solucionar el problema se debe de analizar la propuesta de la solución, se ha cometido un error, puede ser que no de forma directa, pero es un error, el impacto no va a ser más o menos, si es culpa del usuario o de un tercero, así que la solución tiene que estar bien planteada y ejecutada. Antes de empezar a realizar los cambios, actualizaciones y movimientos se debe tratar de analizar y de predecir qué es lo que va a suceder.

La documentación: Este componente es vital, ya que los cambios que se hacen probablemente son algo que se hizo con un tiempo limitado, rápido y que involucraron muchos recursos, así que la documentación es muy importante, ya que puede ser que por las velocidades no se recuerden todos los pasos y cambios que se han realizado. En caso de encontrar algún problema se puede consultar la documentación para detectar si la solución era correcta.

Mecanismos detectivos en seguridad informática

Los mecanismos de detección son los más complejos y son en los que se necesita tener alto grado de conocimientos técnicos dependiendo de la materia que se aborde, por ejemplo, seguridad de plataformas en línea, en específico de un tipo de bases de datos o tecnología como Wordpress, esto depende del sistema, aplicación o el ecosistema que tenga funcionando.

Los mecanismos de detección parten de que se tiene la idea de que un atacante es capaz de violar la seguridad y puede haber realizado una intrusión total o parcial a un determinado recurso. Siempre que se trabaja en los mecanismos de detección se tiene la premisa en mente, se debe de trabajar como si lo que se fuera a encontrar es lo peor y se debe estar preparados para la peor de las situaciones posibles.

Estos mecanismos de detección tienen dos objetivos:

- Poder detectar el punto exacto del ataque para poder llegar a una solución y recuperarse del mismo, pero no siempre es posible esto, depende de los problemas que se afrontan.
- Detectar la actividad que se considera sospechosa y conocer lo sucedido, ya que si no se encuentra donde fue el ataque, lo mínimo que se necesita es saber qué fue lo que sucedió y partir de esa parte.

Lo que es ideal es que se cumpla el objetivo primero, pero no siempre sucede lo ideal, así que se tiene que adaptar al problema, a la situación y todo lo que va saliendo en cada uno de los casos.

Uno de los conceptos que están inmersos en este tipo de mecanismos es la **intrusión**, la cual se la define como una secuencia de acciones realizadas de forma deshonestas, en donde la mayoría de las ocasiones se quiere lograr acceso no autorizado. Dentro de los mecanismos de detección el término más famoso de seguridad informática es el de detección de intrusiones, la cual se define como el proceso de identificación y respuesta ante las actividades ilícitas observadas contra algunos recursos de la red, sistema, plataforma o empresa.

Los mecanismos de detección de intrusión tienen unos pasos que se ejecutan como manera básica de detección que se menciona a continuación:

Revisión de patrones de acceso: En este caso lo que se hace es ver los patrones de acceso, esto quiere decir que se va a analizar los accesos y tratar de encontrar si se está manejando un patrón, por ejemplo, acceso a determinadas horas o el mismo usuario haciendo accesos a la misma sección o módulo. Los patrones siempre van a indicar algo, pueden ser muchos o las mayorías falsas alarmas, pero es seguro, que si se hizo un ataque se puede encontrar patrones que llamen la atención para después encontrar el problema.

Revisión de transacción: En la mayoría de los casos se obtienen ciertos archivos o se intenta descargar o subir algo de información, así que la transacción es un método muy rápido para lograr esto, la mayoría de los intentos van a ir acompañados de al menos una transacción, esto no es una garantía, pero es algo muy probable, siempre durante la detección si se logra encontrar una transacción es como encontrar el objetivo del atacante lo cual es muy valioso.

Bloqueo automático: Algunas aplicaciones no tienen un sistema de bloqueo, así que, aunque en algunos casos se encuentre el problema y ya se tenga las razones, si no se cuenta con un mecanismo de bloqueo de emergencia, el atacante podrá seguir haciendo lo que quería. Algunos de los mecanismos de bloqueo comunes son los de paro absoluto, es decir el bloqueo del sistema completo, es algo un poco drástico, pero en muchas ocasiones no se quiere otro riesgo y se considera la mejor opción a la mano.

Concepto de encriptación en seguridad informática

La encriptación o también conocido como cifrado, es un procedimiento en el que se busca que la información sea ilegible, ya aplicado este procedimiento la información es inservible para cualquier persona que no sea la autorizada, aunque el mensaje sea interceptado, como en muchos casos la información simplemente no significa nada para el interceptor, ya que no cuenta con los elementos involucrados en la encriptación, así que la información simplemente no sirve, la Figura 2 muestra un ejemplo de encriptación.



Se puede decir también, que la encriptación busca la seguridad y la persistencia de los datos mediante un proceso en el cual se involucran algunas partes claves dependiendo del método, por ejemplo, en algunos métodos se utilizan contraseñas o llaves para autenticar la encriptación y la desencriptación de la información, siempre se debe de recordar los objetivos principales de la encriptación y cifrado de datos que se nombran a continuación:

- Confidencialidad
- Autenticación
- Integridad de los datos

La confidencialidad consiste en que la información sólo puede ser accedida por su legítimo dueño o destinatario, la autenticación quiere decir que el emisor y el receptor son los que pueden confirmar la identidad, finalmente la integridad de la información significa que no debe ser posible que sea alterada en caso de que sea interceptada la información.

Existen muchas amenazas de varias fuentes principalmente de internet que pueden ser:

- Correos electrónicos infectados por virus
- Firewalls mal configurados
- Suplantación de contraseñas
- Contraseñas débiles
- Robo y destrucción de información, etc.

Métodos de encriptación

Algunos de los métodos de encriptación disponibles actualmente y que son bastante conocidos se puede mencionar a:

- Encriptación simétrica
- Encriptación asimétrica de clave pública y privada
- Encriptación WPA
- Encriptación WEP
- Firma digital

Estos métodos mencionados anteriormente son la mayoría que se va a encontrar en el mundo de la seguridad informática. Estos métodos de encriptación son bastante buenos para almacenar y transferir la información.

Encriptación simétrica

Este tipo de criptografía está basado en métodos criptográficos que usan una misma clave para cifrar y descifrar el mensaje, estos extremos cuando establecen la comunicación deben establecer un acuerdo sobre la clave que tienen que usar, para posteriormente los dos tener

acceso a la misma clave, en donde el remitente cifra el contenido de la misma y el destinatario la descifra con el mismo mecanismo. Se puede indicar varios ejemplos de cifrado simétrico.

- Algoritmo de cifrado DES, usa claves basados en 56 bits
- Algoritmos de cifrado 3DES, Blowfish, e IDEA, usan claves de 128 bits
- Algoritmos de cifrado RC5 y AES

Encriptación asimétrica

También se indica que este tipo de encriptación se basa en que si el emisor cifra la información el receptor lo puede descifrar o viceversa, en este caso cada usuario del sistema debe poseer una pareja de claves y se tiene dos tipos.

- Clave privada: Custodiada por el propietario, por lo tanto, solo él tiene acceso a ella sin darla a conocer a nadie.
- Clave pública: conocida por uno o todos los usuarios

Como ejemplo de este tipo de algoritmos usados por este tipo de cifrado se tiene a **MD5** y **SHA**.

Firma digital

La Firma digital, es algo habitual en el uso de documentos oficiales, es decir documentos que involucran a una institución gubernamental. El objetivo de la firma es autenticar la identidad de quién envía el mensaje y quién firma el documento, las firmas digitales acostumbran a manejar diferentes datos, además de información que se envía, por ejemplo, la hora y la fecha en que se hizo.

La firma digital es una forma matemática de adjuntar la identidad de una persona a un mensaje, está basada en la criptografía de clave pública, esto quiere decir que estos sistemas están utilizando dos claves, la primera sería la clave pública que es la que se conoce y la otra clave sería una clave privada que es la que solamente el emisor del mensaje conoce.

Encriptación WEP y WPA

La encriptación WEP y WPA tienen algo en común, las dos son aplicadas a las señales inalámbricas y están basados en protocolos de conexión Wifi la primera y la segunda se basa en servidores de autenticación.

En el caso de WEP se tiene tres opciones, de 64 bits, de 128 bits y 256 bits, en donde la más utilizada es la de 128 bits ya que ofrece un buen nivel de seguridad sin tener que ser tan grande y sin aumentar lo complicado del tema. Actualmente la encriptación de 256 bits aún no es soportada por todos los dispositivos.

Existen siempre diferentes opiniones de cómo es que se puede considerar a un método de cifrado, como un buen método de cifrado o un método confiable, pero se puede llegar a una conclusión, un sistema de cifrado se puede considerar como bueno cuando la seguridad de cifrado consiste en la clave y no en el algoritmo.

Aunque se conozca el algoritmo, no se puede llegar a un descifrado de la información gracias a la clave. La mayoría de las aplicaciones que se dan a la encriptación hoy en día son:

- Mensajes de autenticidad
- Facturas electrónicas
- Banca electrónica
- Votos electrónicos
- Notificaciones
- Mensajería instantánea
- Correos electrónicos
- Almacenamiento de información

Ataques. Clasificación de Ataques:

Los ataques a las redes pueden ser definidos como diferentes tipos de actividades sistemáticas dirigidas a disminuir o corromper su seguridad. Desde este punto de vista, un ataque puede ser definido como una amenaza sistemática generada por una entidad de una manera artificial, deliberada e inteligente.

Las redes de ordenadores pueden ser vulnerables a muchas amenazas utilizando distintas formas de ataque, entre ellas:

- Ingeniería social, alguien trata de acceder usando medios sociales (haciéndose pasar por un usuario legítimo o el administrador del sistema, engañando a la gente para que le revelen secretos o claves, etc.). Esta vía de ataque suele dar muchos resultados a los atacantes.
- Ataques de denegación de servicio, incluyendo todos los tipos de ataques destinados a saturar a un ordenador o a una red, de tal manera que los usuarios legítimos no pueden utilizarla.
- Ataques a determinados protocolos, aprovechando debilidades conocidas.
- Ataques a servidores, que aprovechan las vulnerabilidades de ciertos sistemas operativos de los ordenadores o vulnerabilidades en la configuración y administración del sistema.
- Adivinar contraseñas; las contraseñas son secuencias de símbolos, generalmente asociadas a un nombre de usuario, que proporcionan un mecanismo para la identificación y la autenticación de un usuario en particular. En casi todos los servicios son los propios usuarios quienes eligen sus contraseñas, y con frecuencia eligen secuencias que no pueden ser consideradas seguras (por ejemplo, nombre de la pareja, nombre de hijo/hija, fechas de nacimiento, ...) Como regla general, las contraseñas que son fáciles de recordar son también fáciles de adivinar.
- Espionaje de todo tipo, incluyendo la captura de mensajes de correo electrónico, archivos, contraseñas y otra información a través de una conexión de red que permite capturar todos los mensajes de un usuario.

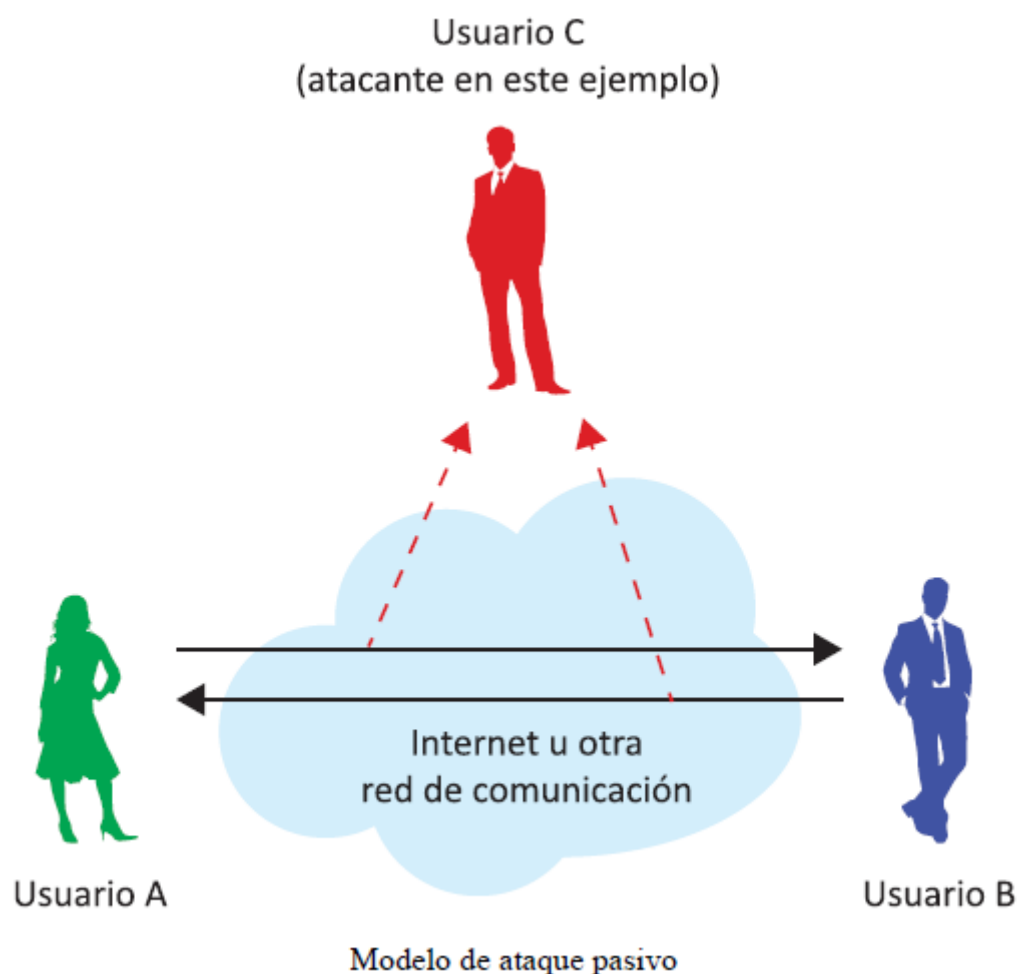
Los ataques de seguridad pueden clasificarse en Ataques pasivos y activos.

Ataques pasivos

Un ataque pasivo es aquél en que el atacante monitoriza el canal de comunicación sin modificar ni añadir datos. Un atacante pasivo sólo pone en peligro la confidencialidad de los datos. El objetivo del atacante es obtener la información que se está transmitiendo.

Los ataques pasivos están relacionados con el contenido del mensaje y con el análisis de tráfico: **Espionaje.** En general, la mayoría de la información que se transmite utilizando una red de comunicaciones se envía de forma no segura (sin cifrar) permitiendo a un atacante "escuchar" o interpretar (leer) los datos intercambiados. Uno de los mayores problemas a los que se enfrenta un administrador de una red deriva de la capacidad de un atacante para monitorizarla. Sin servicios de cifrado (basados en el uso de técnicas criptográficas), los datos pueden ser leídos por otras personas a medida que circulan por la red.

Análisis de tráfico. Se refiere al proceso de interceptar y examinar los mensajes con el fin de deducir información de patrones en la comunicación. Se puede realizar incluso cuando los mensajes están cifrados. En general, cuanto mayor es el número de mensajes observados, interceptados y almacenados, más se puede inferir del tráfico. El análisis de tráfico, entre otras cosas, permite a un atacante verificar que dos entidades están manteniendo una comunicación en un determinado momento.



Ataques activos

Un ataque activo intenta alterar los recursos del sistema o afectar a su funcionamiento. En este tipo de ataque el adversario intenta borrar, añadir, o modificar los datos transmitidos. Un atacante activo amenaza la integridad de datos y autenticación, así como la confidencialidad. Los ataques activos engloban alguna modificación del flujo de datos o la creación de datos falsos. Puede dividirse en seis categorías:

Suplantación de identidad. Es un tipo de ataque en el que el atacante suplanta la identidad de otro usuario.

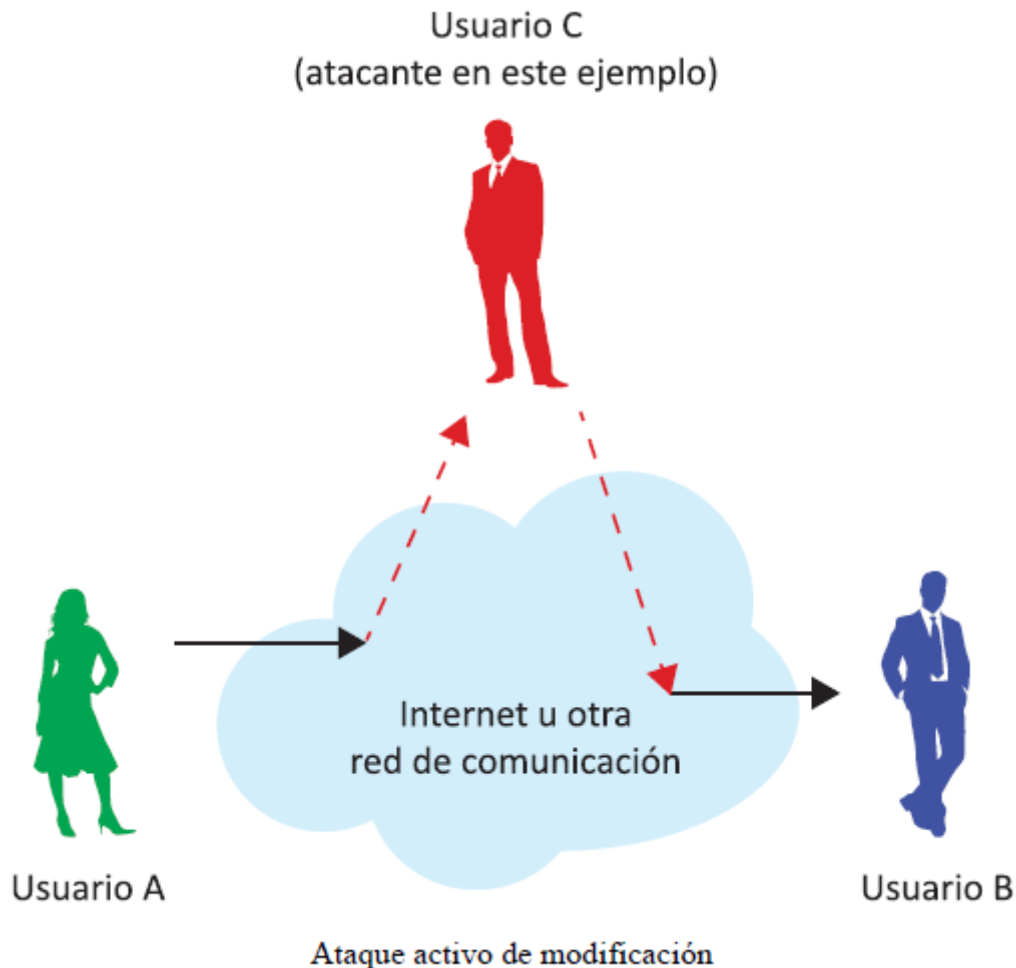
Repetición. En este tipo de ataque, una transmisión de datos válida es repetida o retardada de forma maliciosa. Este ataque lo puede provocar el mismo emisor de datos originales o bien un atacante que los intercepta y después los retransmite, posiblemente como parte de un ataque de suplantación de identidad.

Modificación de mensajes. El atacante elimina un mensaje que atraviesa la red, lo altera, y lo reinserta.

Hombre en el medio (Man in the Middle, MitM). En este tipo de ataques, un atacante intercepta las comunicaciones entre dos entidades, por ejemplo, entre un usuario y un sitio web. El atacante puede utilizar la información que consigue para luego suplantar la identidad del usuario o realizar cualquier otro tipo de fraude.

Denegación de Servicio (Denial of Service DoS) y Denegación de Servicio Distribuida (Distributed Denial of Service, DDoS). Una **denegación de servicio** (DoS) es una situación en la que un usuario u organización se ve privado de los servicios o recursos que normalmente debería tener. En denegación de servicio distribuida, un gran número de sistemas comprometidos (a veces llamado botnet) atacan a un solo objetivo.

Amenazas Avanzadas Persistentes (*Advanced Persistent Threat, APT*). Es un ataque a la red en el que un atacante consigue un acceso no autorizado a la red y permanece allí sin ser detectado durante un largo período de tiempo. La principal intención de un ataque APT es robar datos más que causar daños a la red u organización. Algunas organizaciones que pueden ser objetivo de ataques APT son sectores con alto valor informativo, como la defensa nacional, la industria financiera.



Ataques: Objetivos y Comportamientos

Un atacante o intruso es un individuo que obtiene, o trata de obtener, permisos o acceso no autorizado al sistema de información.

Existen muchos enfoques sobre la forma de clasificar a los atacantes. Los criterios utilizados habitualmente se pueden dividir en los siguientes tres grupos:

- La ubicación del atacante respecto al sistema atacado.
- Nivel de conocimiento del atacante
- Objetivo – por qué se ha realizado el ataque

Desde el punto de vista de la ubicación del atacante, existen dos tipos diferentes de atacantes:

- Atacante interno
- Atacante externo o intruso

Un **atacante interno** es, en general, una persona que tiene acceso a la red informática interna, y por lo tanto es un usuario legítimo, pero intenta obtener acceso a datos, recursos y servicios del sistema a los que él no debería acceder o bien hacer mal uso de cualquier dato al que esté autorizado.

Un **intruso o atacante externo** es generalmente una persona que no está autorizada a acceder a la red informática interna y desea entrar aprovechando vulnerabilidades del sistema.

Dependiendo del nivel de conocimiento del atacante, la clasificación es:

- Aficionados.
- Profesionales.

Los aficionados llevan a cabo ataques menos peligrosos que los profesionales. Esos ataques están en consonancia con el nivel de formación e instrumentación de los atacantes.

El grupo de profesionales por lo general está constituido por excelentes especialistas en informática o telecomunicaciones, altamente capacitados y cualificados y con acceso a recursos especializados. En la práctica, esto significa que son capaces de generar ataques muy peligrosos con graves consecuencias para los sistemas informáticos y redes.

Un tema muy discutido cuando se trata de la clasificación de atacantes es la división en las dos categorías siguientes

- Hackers,
- Crackers.

Un **Hacker** es una persona con excelentes habilidades en informática o telecomunicaciones, muchas veces con experiencia en proyectos importantes de software y cuyo conocimiento es muy útil para encontrar posibles vulnerabilidades y agujeros de seguridad en los sistemas. La actividad del hacker es útil y provechosa. Incluso hay códigos éticos del comportamiento que debe tener un hacker.

Un **Cracker** es una persona que tiene la capacidad de superar las protecciones de un sistema informáticos y que utiliza sus conocimientos de una manera poco ética. Sin embargo, hay más definiciones de este grupo de atacantes que hacen hincapié en el diferente alcance de sus actividades.

Existen también otros grupos de atacantes, posiblemente el más numeroso sea el de **scriptkiddies**. Se trata de usuarios con conocimientos informáticos bastante limitados. Sus ataques se limitan a ejecutar partes de código que han encontrado en algunas páginas web destinados a aprovecharse de una vulnerabilidad de un sistema. Dichos atacantes no conocen qué acción va a realizar la ejecución de este software, aunque sus efectos suelen tener consecuencias graves.

¿Cómo podemos protegernos?

En esta sección se recomiendan las siguientes prácticas para usuarios domésticos

Use contraseñas robustas

A menudo, la única protección utilizada son las contraseñas. Un identificador de usuario (User ID) es sólo un nombre y requiere una contraseña asociada para poder tener la certeza que se trata de dicho usuario. Por lo tanto, las contraseñas son nuestras claves y debemos protegerlas. Los cortafuegos y sistemas de detección de intrusos no sirven para nada si nuestras contraseñas están comprometidas.

Una contraseña segura es la que no se puede encontrar en cualquier diccionario – castellano, catalán, inglés, alemán, ... Eso significa que una contraseña que no debe ser fácil de adivinar. En general, las contraseñas más largas son más difíciles de adivinar o descifrar que las contraseñas cortas son.

A continuación, se presenta una lista que se puede utilizar para establecer contraseñas seguras:

Usar una combinación de letras sin sentido: Las mejores contraseñas aparentan ser un puro disparate bajo el punto de vista sintáctico. Por ejemplo, si tomamos la frase: "No esperes que me comporte perfectamente y dibuje esa sonrisa radiante" y utilizamos sólo la primera letra de cada palabra, nuestra contraseña sería *neqmcpydesr*.

Incluir una mezcla de caracteres mayúscula, minúscula y numéricos: La contraseña debería incluir alguna letra mayúscula en algún lugar que no fuese el inicio y también algún número.

Las contraseñas largas son mejores: La contraseña debería tener al menos 8

caracteres de longitud.

Las contraseñas deben cambiarse periódicamente: Incluso las mejores contraseñas deben cambiarse periódicamente (cada 60 días aproximadamente) para evitar que sean utilizadas mucho tiempo si alguien las descubre. Muchos sistemas operativos permiten configurar esta regla para cada usuario. Aunque desde el punto de vista de usuario esta regla no es práctica, bajo un punto de vista de seguridad resulta muy conveniente.

Generar nuevas contraseñas en lugar de reutilizar las mismos una y otra vez: Una contraseña no debería ser utilizada de nuevo por un usuario en un periodo de tiempo inferior a un año.

No utilizar un conjunto de caracteres consecutivos en el teclado: Debe evitarse el uso de contraseñas como *qwerty*, *12345678*, o *asdfghj*. Aunque aparentemente son texto sin sentido, estas secuencias siguen patrones vinculados a la posición de las teclas en el teclado y se pueden romper fácilmente.

Tratar las contraseñas de forma totalmente secreta Las contraseñas no se comparten y tienen que estar protegidas. Muchos usuarios escriben sus contraseñas en notas adhesivas pegadas a sus ordenadores o las ponen debajo de sus teclados. ¡Eso no sirve para nada!

Para un atacante las contraseñas de administrador son las llaves del reino. Los administradores del sistema con privilegios de root - es decir, sin restricciones de acceso y la capacidad de hacer cualquier tipo de cambios - deben tener contraseñas muy difíciles de adivinar y deben seguir las normas más estrictas respecto al cambio y reutilización. Se recomienda que un administrador cambie TODAS las contraseñas de usuario si sospecha que se ha comprometido su clave.

Del mismo modo, si un usuario general sospecha que la contraseña ha sido robada o comprometida, debe cambiarla inmediatamente.

Usar siempre protección antivirus

El software antivirus no es siempre efectivo 100%, pero es mejor que no tener ninguna protección en absoluto. Es muy posible que un usuario que no haya instalado un antivirus en su ordenador piense que no tiene ningún virus aunque probablemente su equipo esté infectado.

El software antivirus consta de dos partes: el *motor de análisis* y los *archivos de firma*. Es necesario actualizar periódicamente tanto el motor de análisis como los archivos de firmas, sino el software antivirus pierde su capacidad. El software antivirus generalmente contiene un comando de actualización, o bien se puede consultar si hay actualizaciones pendientes en el sitio Web del fabricante.

El motor de análisis le indica al software cómo y dónde realizar la búsqueda, y los archivos de firma son esencialmente una base de datos de virus conocidos y sus acciones. El motor de análisis compara los archivos que contiene el ordenador con los virus conocidos que hay en los archivos de firma. El archivo de firma contiene los patrones de virus conocidos. El software antivirus puede equivocarse indicando falsos positivos (ficheros correctos que son considerados como virus). Cuando se encuentran nuevos virus, los vendedores de software antivirus actualizan sus archivos de firmas para incluir estos nuevos virus. En ocasiones, también el motor de análisis requiere una actualización. Si se actualiza una parte del programa y la otra queda obsoleta, el software no funcionará correctamente.

Con el fin de lograr la máxima protección, es necesario instalar el software antivirus tanto en equipos individuales, como en todos los servidores de la red.

Esa es la única manera de detectar virus en todos los puntos de entrada. Todos los medios extraíbles, como unidades de memoria USB, CD, ... deben ser analizados antes de utilizarse en un sistema. Si el software antivirus está instalado en los cortafuegos se podrán detectar los virus que vienen de las conexiones externas, en particular de Internet.

Cambiar las configuraciones predeterminadas

Uno de los errores más habituales es instalar un sistema dejando la configuración por defecto. Las configuraciones predeterminadas a menudo tienen cuentas de administrador

predeterminadas y contraseñas que conocen todos los piratas informáticos. Esto es aplicable a routers, hubs, switches, sistemas operativos, sistemas de correo electrónico, bases de datos, servidores web...

Además de tener contraseñas conocidas en los equipos, las configuraciones predeterminadas pueden contener múltiples vulnerabilidades de seguridad y deben ser parcheadas. Antes de poner cualquier ordenador en la red, se deberían cambiar los nombres de cuenta y contraseñas por defecto y aplicar todos los parches de seguridad. Aunque esas tareas impliquen consumir más tiempo en la instalación, ahorrará muchos dolores de cabeza posteriores.

Usar un cortafuego (firewall)

Es muy recomendable usar algún tipo de producto de firewall. Los posibles atacantes exploran constantemente los sistemas que utilizan la mayoría de usuarios en busca de vulnerabilidades conocidas. Los firewalls de red (ya sean basados en software o hardware) pueden proporcionar cierto grado de protección contra estos ataques. Sin embargo, ningún firewall puede detectar o detener todos los ataques, por lo que no es de gran ayuda instalar un firewall si luego ignoramos todas las medidas de seguridad.

No abrir ficheros adjuntos desconocidos en correos electrónicos

Antes de abrir los archivos adjuntos de correo electrónico, debemos estar seguros de conocer el origen de los datos. No es suficiente que el correo haya sido enviado desde una dirección reconocida. El virus Melissa se extendió precisamente porque se originó a partir de una dirección familiar. El código malicioso puede ser distribuido en programas divertidos o tentadores.

Al abrir un archivo adjunto, es importante tener en cuenta el siguiente procedimiento:

1. tener el antivirus esté actualizado
2. guardar el archivo en el disco duro
3. escanear el archivo con un software antivirus
4. abrir el archivo

Para una protección adicional, se puede desconectar el ordenador de la red antes de abrir el archivo.

Debemos tener en cuenta que seguir estos pasos reduce, pero no elimina totalmente la posibilidad de que cualquier código malicioso que haya en el fichero adjunto se extienda desde un ordenador a otros.

No ejecutar programas de origen desconocido

Nunca se debe ejecutar un programa a menos que sepa lo ha desarrollado una persona o empresa de confianza. Además, no se deben enviar programas de origen desconocido a amigos o compañeros de trabajo simplemente porque son divertidos - pueden contener lo que se denomina un caballo de Troya.

Mantener actualizadas todas las aplicaciones, incluyendo el sistema operativo

Los vendedores de software suelen entregar parches cuando se descubre que un programa tiene una vulnerabilidad. La mayoría de los productos disponen de un método para obtener actualizaciones y parches.

Algunas aplicaciones comprueban automáticamente si hay actualizaciones disponibles. Si no es así, es necesario comprobar periódicamente si hay actualizaciones pendientes de instalar.

Apagar el ordenador o desconéctelo de la red cuando no lo use

Es recomendable tener el ordenador apagado o desconectado de la red cuando no está siendo utilizado. En esas condiciones, un atacante no puede atacar a un equipo.

Hacer copias de seguridad de los datos críticos y crear un disco de arranque

Es conveniente guardar una copia de los archivos críticos en un medio extraíble, y almacenar los discos de copia de seguridad en algún lugar lejos del ordenador.

Además, es muy útil crear un disco de arranque para permitir la recuperación de un equipo si hubiese problemas.